

# Clase 189 — Análisis de endpoints con EDR

Parte: 8 — **Blue Team, detección y SOC** · Fuente: *Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases* — Don Murdoch 🕒 Duración estimada: **110 min** · Nivel: **Avanzado**

## 🎯 Objetivo

Entender qué es un EDR (Endpoint Detection and Response), qué telemetría produce, cómo se investiga una alerta de endpoint y cómo se contiene un host. Trabajarás con conceptos y herramientas abiertas equivalentes (Velociraptor, Wazuh, osquery) para practicar sin depender de un producto comercial, y sabrás leer un árbol de procesos y una línea de tiempo de actividad.

## 📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Describir** las capacidades de un EDR: detección, telemetría, respuesta y aislamiento.
2. **Investigar** una alerta reconstruyendo el árbol de procesos y su contexto.
3. **Consultar** el estado de endpoints con osquery/Velociraptor.
4. **Ejecutar** acciones de contención (aislar host, matar proceso) de forma responsable.
5. **Diferenciar** EDR, EPP y XDR.

## 📖 Temas

| # | Tema                                   | Por qué importa                        |
|---|----------------------------------------|----------------------------------------|
| 1 | EPP vs EDR vs XDR                      | Ubicar cada tecnología                 |
| 2 | Telemetría de endpoint                 | La materia prima de la detección local |
| 3 | Árbol de procesos y linaje             | Reconstruir qué pasó                   |
| 4 | Detección conductual vs firmas         | Por qué el EDR ve lo que el AV no      |
| 5 | Respuesta: aislar, matar, recolectar   | Contener sin destruir evidencia        |
| 6 | osquery y consultas de flota           | Preguntar al parque en SQL             |
| 7 | Velociraptor y VQL                     | Caza y DFIR a escala                   |
| 8 | Manipulación (tamper) y evasión de EDR | Conocer los límites del control        |

## 📖 Definiciones y características

- **EDR:** solución que registra actividad de endpoint, detecta comportamientos maliciosos y permite responder remotamente. Característica: telemetría continua + capacidad de acción.
- **EPP (Endpoint Protection Platform):** antivirus/antimalware de prevención. Característica: bloquea conocido; el EDR detecta lo desconocido por comportamiento.

- **XDR:** correlación extendida entre endpoint, red, identidad y nube. Característica: unifica señales que un EDR aislado no ve.
- **Árbol de procesos:** relación padre-hijo de procesos con sus argumentos. Característica: revela el linaje de una ejecución sospechosa.
- **osquery:** expone el SO como tablas SQL consultables. Característica: hunting e inventario en lenguaje familiar.
- **Velociraptor:** plataforma DFIR/hunting con su lenguaje VQL. Característica: recolección forense y caza a escala de flota.
- **Aislamiento de host:** desconecta el endpoint de la red salvo del EDR. Característica: contiene sin apagar, preservando evidencia.

## Herramientas y preparación

En laboratorio aislado:

- **osquery** en Windows/Linux para consultas de estado.
- **Velociraptor** (servidor + cliente) para hunting y colección.
- **Wazuh** (clase 185) como capa de detección de endpoint gratuita.
- **Sysmon** como fuente de telemetría rica.
- Opcional: prueba de un EDR comercial en su edición de evaluación.

Las acciones de respuesta (aislar, matar procesos) se practican solo sobre tus propias máquinas de laboratorio.

## Laboratorio guiado — Investiga y contén un endpoint

1. **Instala la telemetría.** Sysmon + agente Velociraptor + osquery en el Windows de laboratorio.
2. **Genera actividad sospechosa.** En la VM, simula una cadena benigna-pero-anómala (p. ej. `cmd.exe` lanzando `powershell -enc ...` con un script inofensivo).
3. **Reconstruye el árbol.** En Velociraptor, ejecuta un artefacto de listado de procesos o consulta la telemetría Sysmon para ver padre→hijo→nieto.
4. **Consulta la flota con osquery.** `SELECT name, path, parent FROM processes WHERE name='powershell.exe';` y correlaciona con conexiones: tabla `process_open_sockets`.
5. **Construye una línea de tiempo.** Ordena por `_time` los eventos: creación de proceso, archivo escrito, conexión de red.
6. **Contén.** Con Velociraptor, ejecuta un flujo de aislamiento de host de laboratorio y verifica que solo el agente mantiene conectividad.
7. **Recolecta evidencia.** Lanza una colección (procesos, autoruns, prefetch) para preservar el estado antes de remediar.
8. **Documenta.** Resume el incidente: entrada, ejecución, persistencia intentada y acción de contención.

## Ejercicios

1. Escribe 3 consultas osquery para hunting (procesos sin firma, autoruns, usuarios).
2. Explica la diferencia entre matar un proceso y aislar el host, y cuándo usar cada uno.
3. Reconstruye un árbol de procesos a partir de eventos Sysmon.
4. Compara EDR y antivirus con un ejemplo de amenaza que solo uno detecta.
5. Diseña un artefacto de Velociraptor para listar tareas programadas.

6. Enumera 3 técnicas de tamper de EDR y una mitigación para cada una.

## Reto verificable

Investiga una actividad sospechosa simulada en tu endpoint de laboratorio y entrega: árbol de procesos, línea de tiempo, evidencia recolectada y la acción de contención aplicada. **Criterio de aceptación:** reconstruyes correctamente la cadena padre→hijo hasta el proceso sospechoso, muestras al menos una conexión de red asociada, y demuestras que tras el aislamiento el host solo conserva el canal del agente.

## Errores comunes

| Síntoma / mensaje                    | Causa y cómo arreglar                                                        |
|--------------------------------------|------------------------------------------------------------------------------|
| Matas el proceso y pierdes evidencia | Recolecta antes de responder; aísla en vez de apagar                         |
| El EDR no ve el ataque               | Telemetría insuficiente o exclusiones amplias; revisa cobertura              |
| osquery devuelve vacío               | Tabla equivocada o permisos; verifica con <code>.tables</code> y privilegios |
| Host aislado sin poder investigar    | Regla de aislamiento bloqueó también al agente; ajusta la política           |
| Alertas EDR sin contexto de linaje   | Falta correlación padre-hijo; habilita registro de línea de comandos         |

## Preguntas frecuentes

 **¿EDR o antivirus?** Ambos. El EPP/AV bloquea lo conocido y barato de parar; el EDR detecta comportamiento y permite responder. Se complementan; el AV suele ser una capa del EDR.

 **¿Puedo practicar EDR sin comprar uno?** Sí. Velociraptor, osquery, Wazuh y Sysmon cubren los conceptos clave —telemetría, hunting, colección y respuesta— de forma gratuita y realista.

 **¿El EDR es infalible?** No. Existen técnicas de evasión y tamper. Por eso el blue team combina EDR con telemetría de red, identidad y hunting: defensa en profundidad.

## Referencias

- Murdoch, D. *Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases*.
- Velociraptor Documentation — <https://docs.velociraptor.app/>
- osquery Documentation — <https://osquery.readthedocs.io/>
- MITRE ATT&CK, táctica Defense Evasion — <https://attack.mitre.org/tactics/TA0005/>
- Wazuh Endpoint Security — <https://documentation.wazuh.com/>

## Siguiente clase

Clase 190 - Analisis de logs de Windows: Event Logs y Sysmon